

SHIELD Framework — Privacy Without Friction: Secure AI under Bangladesh PDPA

Robi Data Privacy Avengers | Concept Paper | TeamNullX | New Telecom Ltd case

1. Deconstruction of the Problem

New Telecom Ltd must scale six AI services (support assistants, fraud detection, churn prediction, marketing recommendations, network ML, document processing) under PDPA 2026—lawful processing, minimization, accountability, processor control, data-subject rights, and a ban on tracking/profiling/targeting children under 18. Cybersecurity matured, but privacy is fragmented across developers, cloud, AI vendors, analytics, and marketing, so leadership cannot answer where data lives, which AI/vendors touch it, what leaves Bangladesh, whether decisions are explainable and fixable for customers, who is accountable, or how to prove compliance in an audit. Generative AI adds prompt injection, training leakage, bias/opacity, and cross-border third-party retention. The real challenge is delivering **privacy without friction**: strong protection customers barely notice, with fast human recourse when AI gets it wrong.

2. Key Privacy Challenges

Privacy: over-collection; prompts/embeddings/logs/vector DBs as hidden stores; HR data in AI; erasure vs trained models. **Security:** injection, inversion, shadow GenAI, vendor exfiltration. **Ethics:** biased fraud/churn; adult-SIM/child-user age ambiguity. **Compliance:** weak RoPA/processors/cross-border evidence; children's ban. **Customer experience risks:** wrongful fraud blocks, AI chat loops, consent fatigue, app-only dashboards excluding feature-phone/rural users, slow DSARs, and vague breach SMS that also enable scams—rights without usable recourse will not earn trust.

3. Proposed Approach — SHIELD (Proposed Target Architecture)

Architecture & access: Zero Trust (ZTNA, microsegmentation, NGFW); isolated HA AI zone (segmented from billing/subscriber) with mTLS, DR/fail-closed, AI kill switch; ABAC (purpose-bound) + JIT/PAM; FIDO2 MFA (no SMS-only OTP for privileged); HITL with thresholds; UEBA; risk-based step-up for customers. **Data:** TLS/mTLS, TDE, field encryption, tokenization, KMS/HSM; residency tagging; automated discovery + app-to-data inventory; auto-delete prompts/embeddings/logs/training/vector DBs; retrain-on-erasure; masked/synthetic non-prod only. **AI tech:** Hardened RAG (Presidio BD NID/phone/Bangla/eKYC → behaviour analysis + guardrails → retrieve); DP (ϵ policy ≈ 1.0); SHAP for scoring; citations + stored decision logs for LLMs; bias/model cards/drift/rollback; CI/CD PAIA gate + signed artifacts; OWASP LLM Top 10 + MITRE ATLAS. **Children:** age assurance from existing registration/payment data; if uncertain → no profiling; suppress under-18s in marketing/churn; misclassification correction; parent guidance; audits. **Customer trust & experience (core):** reason codes; fraud blocks use step-up or fast human review with temporary-release path + proactive SMS (false-positive KPI); appeal channel; AI disclosure with human handoff after failed turns; Bangla/English/Banglish; privacy dashboard **plus** **USSD/IVR/SMS/retail**; layered notices; granular per-use-case consent; no dark patterns; no service penalty for opt-out; DSAR SLAs with status tracking; privacy complaint/escalation + remediation policy; vulnerable-customer handling; plain-language vendor/cross-border transparency; VoC/usability testing; customer KPIs (CSAT, trust score, false-positive rate, DSAR/appeal SLA). **Third parties & governance:** AIBOM; no-training-on-our-data; tiering; DPAs; exit/deletion; egress monitoring; transfer register; in-country default; independent DPO (veto) + AI & Privacy Council + RACI; CDO; DPIA/PAIA; AI-aware breach playbook within PDPA timelines (verified sender IDs + helpline); VAPT + AI red team + mock PDPA audit + WORM logs (no PII); ISO 42001/27701-aligned. **Not used:** blockchain for personal data; MAC-as-auth; keyword-only filters; public GenAI with personal data (DLP/CASB-blocked); app-only privacy channels.

4. Expected Impact

Customers: control without friction (dashboard + USSD/IVR), safer AI chats with real handoff, fairer fraud handling with fast unblock, children's safety, measurable trust (CSAT/trust KPIs). **Organisation:** answers the eight leadership questions; lower breach/regulatory risk; reusable controls across all six AI uses; audit-ready evidence. **Responsible AI:** privacy-by-design becomes operational (DP, explainability, kill switch, red team)—compliance that sustains innovation and loyalty, not a late veto.

5. Applicability in Bangladesh

SHIELD fits PDPA 2026 and local telecom reality: BD PII recognition (NID, +880/01X, eKYC), Bangla-first inclusive channels for feature-phone and rural users, adult-registered SIMs used by minors, in-country processing default, and regulator-ready transfer/vendor registers. It supports Smart Bangladesh digital trust and transfers to banks, fintech, and public services facing the same AI-privacy tension.

SHIELD: PDPA-ready, customer-centric, Bangladesh-built responsible AI — privacy without friction.